

05 — Security & Authentication

Authentication, authorization, privacy, file security and reliability

CampusFlow • Production Specification • v1.0 • October 2026

1. Authentication

Password hashing: Argon2id or bcrypt cost 12.

Cookies: HttpOnly; Secure in production; SameSite Strict where compatible.

Session expiry: student 8h; admin 2h.

Login rate limit: 5/min per IP + email.

Email: remove whitespace and lowercase.

Temporary initial password: hash immediately; force change when flagged.

2. Authorization

- Never trust a role sent by the browser.
- Derive role from validated server session/JWT.
- Use requireAuth and requireRole middleware.
- Student access to /api/admin returns 403.
- Students cannot publish notices.
- Private audience checks happen server-side.
- Audit logs and role changes are admin-only.

3. Input & File Security

- Zod at every API boundary.
- Sanitize rich text and strip script.
- Supported uploads: PDF/JPG/PNG, maximum 5MB.
- Generate storage keys server-side.
- Prisma parameterization prevents SQL injection.
- Expose safe errors plus requestId.
- SHA-256 hash source files for deduplication.

4. Privacy

- MVP data: name, college email, department, year, division, batch, role.
- Do not collect Aadhaar or phone numbers.
- Students see their own profile and registrations.
- Admin access follows role.
- No public student-email search.
- Audit logs are admin-only.
- Never commit real CSV or .env.

5. Reliability

- Managed PostgreSQL backups; planned Neon deployment.
- GET /health returns status, database state and timestamp.
- Request IDs are logged.
- Notification failure does not roll back the main notice/event transaction.

- Use safe retries only.

6. Acceptance Checklist

- Student cannot call admin APIs.
- Student cannot see another audience's private notice.
- Duplicate event registration is impossible.
- Capacity cannot become negative.
- Login brute force is rate limited.
- Passwords never appear in logs.
- AI key is absent from frontend.
- Upload filename cannot control storage path.
- Rich text cannot execute script.